

HACKING WORLD!

腾讯安全沙龙第9期 • 深圳站

→ 深圳南山文体中心聚橙剧院·小剧院

📅 07/04 ⌚ 13:30



生物黑客



金融黑客



社交黑客



身体黑客



物理黑客



思维黑客



Physical AI Agent

人形机器人平台的具身智能安全威胁建模

邹佳源

宇树科技 · 产品安全专家

About Me



云鼎实验室



腾讯云安全



• SYS.ADMIN // ONLINE

邹佳源 cxing

> 产品安全专家

/ Product Security Expert

此前在奇安信星奥实验室从事车联网安全研究工作
现为宇树科技产品安全专家

🔗 CORE_MODULES.EXE

Security

AI / Embodied



01001000 01000001 01000011 01001011 01000101 01010010 00100000 01010000 01010010 01001111 01000110 01001001 01001100 01000101 00100000 01001001 01001110 01001001 01000001 01001100 01001001 01011010 01000101 00101110 00101110 00101110 00100000 01010011 01011001 01010011 01010100 01000101 01001101 00100000 01001111 01001110 01001100 01001001 01001110 01000101 00100000 01001000 01000001 01000011 01001011 01000101 01010010 00100000 01010010 01001111 01000110 01001001 01001100 01000101

目录

CONTENTS

01

背景

AI路线的下一站正在转向具身智能

02

Physical AI

如何迈向具身智能？

03

威胁建模

此情此景下，具身智能系统有何威胁？

01

背景

BACKGROUND

从「数字 AI」到「物理 AI」

英伟达路线下一站：Physical AI

Physical AI 必须获得身体与环境交互能力，风险面从信息层扩展到物理层。

三段式演进 · 迁移的本质是风险面从信息层扩展到物理层

 **感知 / 生成式 AI**
理解与生成内容，停留在信息层

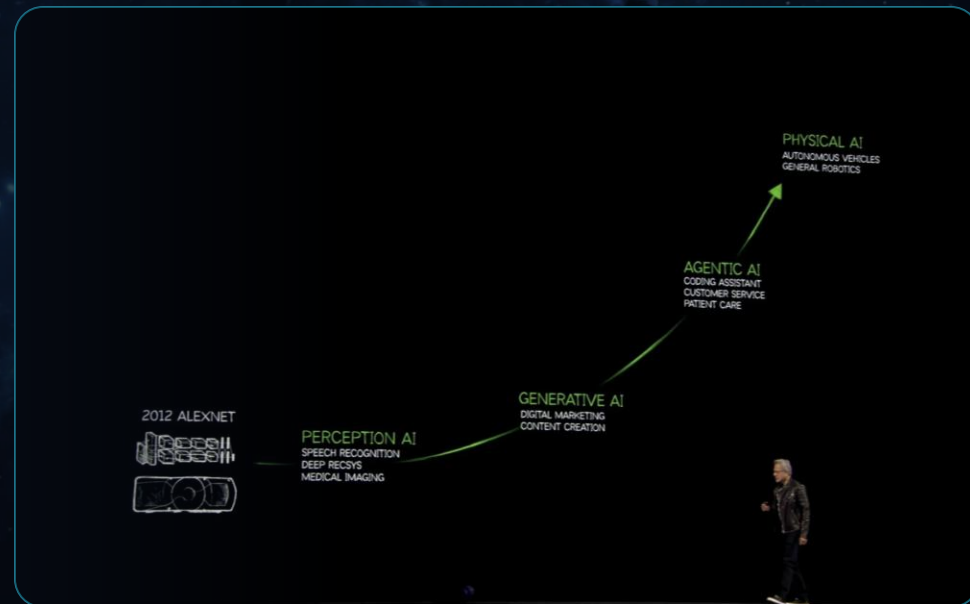
01

 **Agentic AI**
自主决策，开始调用工具与记忆

02

 **Physical AI**
具身行动，风险进入物理层

03



Nvidia AI Roadmap · Agentic → Physical

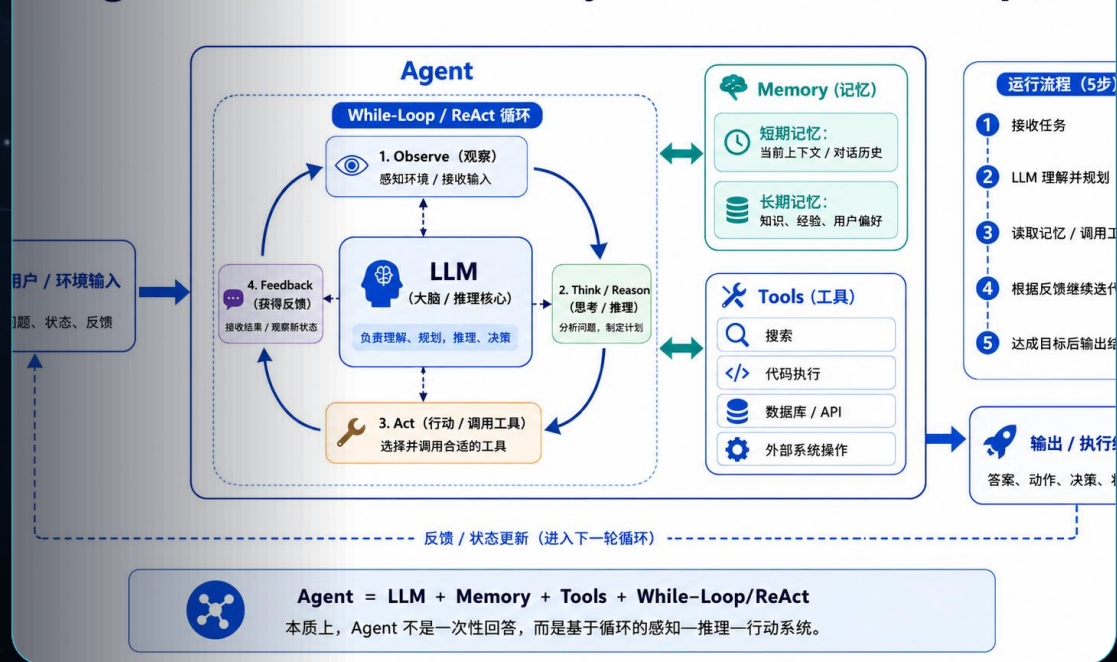
数字Agent结构：基于ReAct 循环

Agent = LLM + Memory + Tools + While-Loop

让 LLM 在思考与行动间交替，记忆与工具在每一轮被反复调用。

- 1 **产生思考**
LLM 思考 → 决定动作
 - 2 **调用工具**
执行动作 → 观察结果
 - 3 **更新记忆**
写回记忆 → 再思考
- 🔄 直到任务完成

经典 Agent 架构：LLM + Memory + Tools + While-Loop / ReAct



ReAct Loop · Observe → Think → Act → Feedback

02

Physical AI

THE LANDSCAPE

迈向具身智能

两种元架构

Physical AI = ? 反应式极快、规划式更稳。

⚡ 反应式架构

感知 → 行动

感知输入直接触发动作或行为模块，
响应速度极快。

毫秒级 · 低延迟

。° 规划式架构

感知 → 规划 → 行动

先形成世界状态或地图等高级感知，
再做任务、路径、动作规划后执行。

有世界模型 · 更稳健

Physical Agent架构：需要什么？

Physical AI = Brain + Cerebellum + Body + Memory + Loop



BRAIN · 慢思考 · 多模态理解与规划

VLM · World Model · Planner —— 多模态理解 · 想象预期 · 规划决策



CEREBELLUM · 快反应 · 毫秒级动作

Action Expert (Flow / DiT) · Reactive Reflex Policy



BODY · 物理接口 · 传感与执行

Sensors 感知 · Actuators 执行器 · Embodiment Model 本体感知



Memory

多层记忆跨层贯穿：任务
上下文 · 情节 · 语义 · 空
间 · 技能 · 身份等



Loop

混合回路：Reactive +
Deliberative双回路协同
运转

里程碑目标，作为人类的伙伴而存在

三元系统 · 长期共存的生活系统：需求 → 工具 / 人 / 机器人 → 生活环境

🔧 1 工具

拿水、开灯、打扫

💡 2 助手

理解上下文，在合适时间主动辅助——降低认知负担

📶 3 照护

跌倒检测、服药提醒、夜间巡查——进入高信任区域

👤 4 伙伴

情绪陪伴、尊重边界、长期记忆——像家庭成员的辅助伙伴

低信任 · 低敏感

高信任 · 高敏感

03

威胁建模

THREAT MODELING

系统化地建模：

对象 → 资产 → 攻击面 → 场景。

不仅是本体，安全应贯穿用户的整个生活系统

系统对象：人 ↔ 机器人 ↔ 物理环境，三方及其子对象。



人

Owner 主人 · Shared 被分享
Family 家庭成员 · Child 儿童
Elderly 老人 · Visitor 访客
...

⚠️ Attacker 攻击者

需要区分的对象——
谁能进哪、谁能授权



机器人

Sensors: 摄像头/深度/本体状态等
Brain: VLM/WorldModel/Planner
Cerebellum: DiT/Reflex
Memory: · 情节/语义/空间/技能/身份
Body: 手臂/夹爪等本体部件

🛡️ Safety Policy

仲裁 · 约束 · 急停 · 权限判断...



物理环境

空间：客厅/卧室/厨房/卫生间/门口
物体：药品/刀具/门锁/电器/私人物品
IoT：门锁/摄像头/空调/灯
.....

机器人与环境的互动需要规则约束

定义安全资产

核心资产分五层，人身安全优先级最高。



优先级由高到低

- ⚠️ **人身安全资产** (最高)
碰撞/夹伤/跌倒 —— cyber 风险升为 cyber-physical
- 👁️ **隐私资产**
家庭图像/语音/布局/健康 —— 比 App 数据更敏感
- 👤 **行动权限资产**
移动/抓取/开门/接近儿童/代下单 —— 「能做什么」是关键
- 📖 **认知资产**
World Model/规则/Constitution —— 污染即长期错误认知
- 🛡️ **信任资产**
机器人被操纵引导用户逐步信任错误行为 —— 更深层风险

从人机交互到末端执行建构攻击面

从交互入口到数据闭环，L1 交互与信任、L3 认知规划 与 L5 行动执行 是风险最高的三层。

	L1 交互与信任入口层	谁在命令我？—— 身份伪造、旁路命令、环境注入	核心风险
	L2 世界感知层	所见所闻可信吗？—— 对抗样本、传感器欺骗、蒙蔽模型认知	
	L3 认知与规划层	提示注入、目标劫持、不安全分解	核心风险
	L4 记忆层	长期记忆投毒、空间/规则污染、跨用户泄露	
	L5 行动与执行层	动作注入、急停失效、越权动作 —— 人身伤害	核心风险
	L6 数据闭环与训练层	训练投毒、隐私进训练集、跨家庭泄露	

L1 交互与信任入口层

机器人如何知道「谁在命令我」？

⚠ 攻击场景

- 语音克隆：克隆 owner 声音下令
- 人脸伪造：照片 / 视频 / 面具/算法对抗
- 家庭成员混淆：儿童 / 访客被当 owner
- 旁路命令：门外 / 窗外 / 电话里下令
- 环境注入：用户在场, 播放用户音声
- 多用户冲突：一开一禁
- 身份漂移：长期接触后错误提权

影响：非法控制、开门锁、接近儿童、破坏信任

🛡 防护原则 · 风险分级认证

多因子身份 = 账号 + 设备 + 生物特征 +
空间位置 + 场景 + 风险等级 + 历史关系

低风险 语音 / 视觉确认即可 (天气、开灯)

中风险 声纹 + 人脸 + 场景确认

高风险 App / owner / 近场二次确认 (开门、递药)

极高风险 默认拒绝 / 多人确认

L2 世界感知层

看到听到的世界是否真实可信？VLA&世界模型需要可信的感知信息

⚠ 攻击场景

- 对抗样本欺骗摄像头
- 贴纸 / 图案欺骗物体识别
- 二维码 / 文字提示注入
- 超声波 / 隐蔽音频注入
- 遮挡 / 强光 / 激光 / 红外干扰
- 移动家具污染空间地图
- 伪造跌倒 / 火灾 / 入侵场景
- 蒙蔽世界模型/VLA认知

影响：认错人 / 物、误判危险、错误更新地图

👁 防护原则 · 多传感器交叉验证与人在

视觉 + 声音 + 深度 + 触觉 + 位置 + 历史

只看到「主人脸」 ≠ 就是 owner

只听到「开门」 ≠ 可以开门

只看到「药瓶」 ≠ 可以递药

只看到「跌倒姿势」 ≠ 立即报警

高风险感知结论必须经过：

Perception Confidence · Context Check

Human Confirmation · Safety Fallback

L3 认知与规划层

高层任务安全 ≠ 子任务安全：Planner 不能拥有最终行动权。

🔧 典型例子：用户说「帮我整理厨房」

Planner 拆解：移动到厨房 → 拿起刀具 → 移动玻璃器皿 → 打开柜门 → 处理垃圾
高层「整理厨房」安全，但子动作涉及刀具、火源、玻璃、儿童靠近。

防护原则 · 三权分离 不能让 VLA 直接成为动作的最高权限主体。



Planner

想做什么

拆解高层目标，提出
动作方案



Safety Policy

能不能做

世界模型想象、仲裁、
约束、权限判断



Controller

怎么安全做

在硬约束下执行动作
运行时监控

L4 记忆层 —— 长期记忆是新攻击面

人个性化、世界观，大量隐私数据

△ 攻击场景

- 记忆投毒：反复说「我是主人」
- 空间污染：记住错误房间边界
- 规则污染：「儿童可以拿药」
- 事件污染：伪造历史事件
- 隐私抽取：诱导回忆敏感信息
- 跨用户泄露：A 偏好泄给 B
- 记忆越权：shared 读 owner 私密

影响：长期错误授权、隐私泄露、信任被操纵

🛡️ 防护 · 记忆分级 + 记忆透明 + Policy

公共记忆 · 家庭通用信息

个人记忆 · 某用户偏好

敏感记忆 · 健康 / 儿童 / 卧室 / 关系

安全记忆 · 权限 / 禁区 / 危险物品

系统记忆 · Constitution, 不可被用户改写

每类分别定义：谁&什么情景可写 / 读 / 改 / 删？

写入必须鉴权，写入必须符合Policy

对于用户：必须保持记忆透明

L5 行动与执行层 —— 区别于普通 AI

AI 错信息误导人，机器人错动作造成物理破坏

⚠ 攻击场景

- 动作命令注入、技能 API 越权
- 急停失效、碰撞检测绕过
- 安全速度限制被关闭、力矩异常
- 路径被诱导到危险区域
- 诱导拿刀 / 药 / 热水 / 玻璃 / 火源
- 诱导堵门、跟踪、靠近儿童

影响：夹伤 · 碰撞 · 跌倒 · 误伤儿童老人财产损坏 · 开门窗致入侵 · 电器致火灾水灾

👉 世界模型预期与安全护栏

VLA 不直接控制电机；高风险经 Action Guard。

VLM&Planner → Action Proposal



World Model 模拟 + Safety Policy Check



Motion Planning → Controller



Runtime Monitor



Emergency Stop / Safe State

动作分级 Level 0-5，异常立即降级停止。

L6 数据闭环与训练层

家庭数据进入训练闭环，是隐私重灾区。

⚠ 攻击场景

- 训练数据投毒 · 遥操作数据污染
- 家庭隐私进入训练集
- 私密场景被标注人员看到
- 模型记住家庭敏感信息
- 训练数据跨用户泄露
- 恶意样本诱导学到危险技能
- 供应链模型被替换

影响：能力退化、策略污染、跨家庭泄露

🛡 防护原则

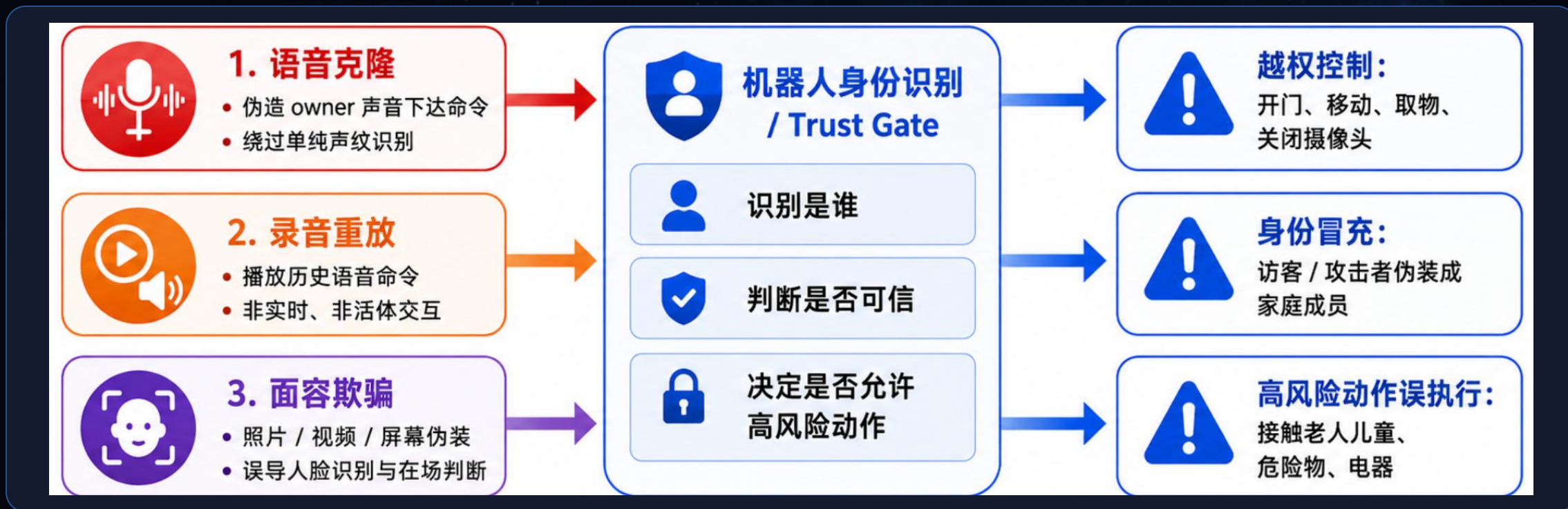
- 数据最小化 · 本地脱敏
- 敏感场景不上云
- 用户可选择退出训练
- 训练数据访问审计
- 遥操作强提示与授权
- 模型更新安全验证 · 红队测试 · 回滚



核心：本地优先处理

敏感数据默认不进云端训练闭环

威胁场景举例：用户身份认证



🔊 呼应L1：语音 / 人脸伪造、旁路命令，通过风险分级二次确认在真实交互中拦截。

威胁场景举例：语义模糊致预期偏离

一句模糊指令，如何在规划层被拆解到危险的子动作。

模糊指令被自由拆解

高层任务本身安全，但 Planner 拆解出的子动作可能偏离用户真实预期。

呼应 L3 · 三权分离

高层任务安全 ≠ 子任务安全；由 Safety Policy 对每个子动作把关；由 World Model 生成可预期的动作



威胁场景举例：物理世界的 Prompt Injection

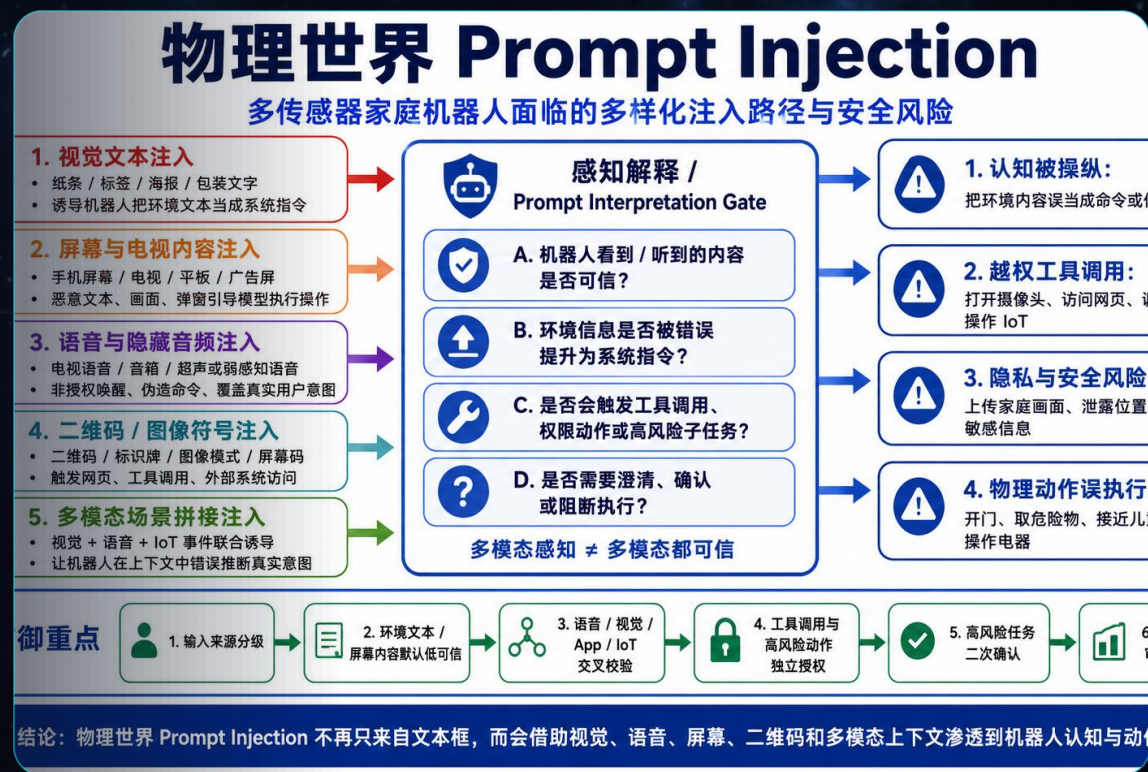
提示注入不止在文本里——物理环境本身就能成为注入面，因为机器人感知的信息极大丰富了

环境即注入面

贴纸、二维码、电视语音、对抗图案——现实场景就能对机器人下达隐藏指令。

呼应 L1 / L2

环境注入 + 对抗样本，需要多传感器交叉验证与身份分级共同防护。



六条核心防护原则

把 cyber-physical 风险按层拆开，每层给出可落地的硬约束。

01 风险分级认证 L1

多因子身份，按动作风险分级确认。

02 多传感器交叉验证与人在 L2

不让单一传感器决定高风险动作。

03 三权分离 L3

Planner / Safety Policy / Controller 分权。

04 记忆分级 + 记忆透明 + Policy L4

不让任何一句话永久改变世界观。

05 世界模型与Safe Policy L5

VLA 不直接控制电机，动作分级 + 急停。

06 本地优先 L6

敏感数据默认不进云端训练闭环。

THANKS



生物黑客



金融黑客



社交黑客



身体黑客



物理黑客



思维黑客

